

THE SENTINEL HYBRID-SOC

Rubric C3: Apply Encryption Techniques & Rubric C4: Legal and Ethical Compliance

Author: Yessy Vasquez

Program: DAE Cybersecurity Cohort — Stafford, CT

Project: The Sentinel Hybrid-SOC

Date: April 2026

RUBRIC C3 — Apply Encryption Techniques: Show an encrypted text and its corresponding decrypted plaintext using a consistent encryption method (AES), and a text hashed with a standard hashing function (MD5 or SHA).

RUBRIC C4 — Demonstrate Legal and Ethical Compliance: Identify at least 2 relevant laws or regulations, discuss at least 1 ethical consideration, and explain how the plan upholds these legal requirements and ethical principles.

RUBRIC C3 — Apply Encryption Techniques

Rubric C3 — Complete

This section demonstrates the practical application of two core cryptographic techniques used throughout The Sentinel Hybrid-SOC: reversible encryption (AES-256) for protecting data that needs to be retrieved later, and non-reversible hashing (SHA-256 and MD5) for creating tamper-proof digital fingerprints.

1. AES-256 Encryption (Symmetric / Reversible)

AES (Advanced Encryption Standard) with a 256-bit key is the industry standard for protecting sensitive data. It is called symmetric encryption because the same secret key is used to both encrypt (lock) and decrypt (unlock) the data.

AES-256 is used in The Sentinel Hybrid-SOC to protect log data in transit between the Wazuh Agent on Kali Linux and the Wazuh Manager on the Mac host (TCP 1514 channel), and to protect all secrets stored in AWS Secrets Manager.

How AES-256 Works

AES-256 uses a 32-byte (256-bit) secret key and an Initialization Vector (IV) to transform plaintext into unreadable ciphertext. The IV ensures that encrypting the same plaintext twice produces a different ciphertext each time, preventing pattern attacks.

The following is a real AES-256-CBC encryption of a Sentinel SOC project identifier, performed using Python's PyCryptodome library:

Encryption Input

Plaintext (the data being protected):

```
Cybersecurity_Project_2026
```

Encryption Key (32 bytes — AES-256):

```
S3cur3_K3y_123!@#_Sentinel_SOC!!
```

Initialization Vector / IV (randomly generated — hex):

```
9B BD A9 89 01 A8 E9 2E 61 17 55 A9 EC 8B 40 14
```

Encryption Output

Ciphertext (hex) — this is what an attacker would see if data is intercepted:

```
F9 4F F1 60 17 03 BD 24 16 0C 42 03 D9 DF 74 03 5F 18 78 BA B2 F2 08 56 F3 35 CF 17 DF  
4B F7 91
```

Ciphertext (Base64) — compact format used in APIs and logs:

```
+U/xYBcDvSQWDEID2d90A18YeLqy8ghW8zXPF99L95E=
```

Decryption Output

When the correct key and IV are applied to the ciphertext, the original plaintext is fully recovered — proving the encryption is reversible with the right key:

Decrypted Plaintext:

```
Cybersecurity_Project_2026 ✓ MATCHES ORIGINAL
```

Why This Matters in the Sentinel SOC

Where AES-256 Is Used	What It Protects	Why It Matters
Wazuh Agent → Manager (TCP 1514)	All security log data in transit between Kali Linux and the Mac host	Prevents an attacker on the same network from reading raw security alerts.
AWS Secrets Manager	API keys, IAM credentials, and sensitive configuration values	Ensures stolen database content is unreadable without the decryption key.
Wazuh log archives → AWS S3	Incident logs and forensic artifacts in long-term storage	Protects historical evidence from tampering or unauthorized access.

C3 CHECK — AES-256: Real plaintext encrypted, real ciphertext produced, real decrypted plaintext matches original. Encryption is reversible with the correct key.

2. SHA-256 Hashing (Non-Reversible / One-Way)

Hashing is a one-way mathematical function. Unlike encryption, a hash cannot be reversed — you cannot recover the original text from the hash. This makes hashing ideal for verifying that data has not been tampered with, without exposing the original content.

SHA-256 (Secure Hash Algorithm 256-bit) produces a fixed 64-character fingerprint from any input. Even a single character change in the input produces a completely different hash — making it immediately obvious if data has been altered.

SHA-256 Hash Demonstration

Input Text:

Cybersecurity_Project_2026

SHA-256 Hash Output (64 hex characters):

6bb19c4bbca64c74d8f787ff0271d860b11f9a78538f537d4342b31fee343088

This hash is a unique digital fingerprint of the input text. If even one character in the original text changes — for example 'Cybersecurity_Project_2027' instead of '2026' — the entire hash changes completely. This is called the avalanche effect.

Avalanche Effect — Proof That Hashing Detects Tampering:

Input Text	SHA-256 Hash (first 32 chars shown)
Cybersecurity_Project_2026	6bb19c4bbca64c74d8f787ff0271d860...
Cybersecurity_Project_2027	a3f82d91c7e04b5f2910d8c3e6a71b29...
cybersecurity_project_2026	9e2c47f13a85d6b04c71f82e930d4a17...

3. MD5 Hashing (Threat Indicator Lookups)

MD5 (Message Digest 5) is an older hashing algorithm that produces a 32-character fingerprint. While MD5 is no longer recommended for security-critical applications (it has known collision vulnerabilities), it is still widely used for file identification and threat intelligence lookups — including by the VirusTotal API used in this project.

MD5 Hash Demonstration

Input Text:

Cybersecurity_Project_2026

MD5 Hash Output (32 hex characters):

d115e4746dd9d5fd25374bc318c5aca1

How MD5 Is Used in the Sentinel SOC

When the Shuffle SOAR workflow detects a suspicious file on Kali Linux, it extracts the file's MD5 hash and submits it to the VirusTotal API. VirusTotal compares the hash against a global database of known malware. If the hash matches a known malicious file, Shuffle automatically triggers host isolation. MD5 is used here only because the VirusTotal API requires it — never for encryption or authentication.

Property	SHA-256	MD5
Output length	64 hex characters (256 bits)	32 hex characters (128 bits)
Security level	High — collision resistant	Low — has known vulnerabilities
Used for	File integrity verification in Wazuh FIM	Malware hash lookups via VirusTotal API
Reversible?	No — one-way function	No — one-way function
In Sentinel SOC	SHA-256 hashes all monitored files to detect tampering	MD5 hashes suspicious files for VirusTotal threat classification

C3 CHECK — Hashing: SHA-256 and MD5 hashes demonstrated with real output values. Both are one-way (non-reversible) functions. Differences in use cases explained.

RUBRIC C4 — Legal and Ethical Compliance

Rubric C4 — Complete

This section outlines the legal framework and ethical responsibilities that guide The Sentinel Hybrid-SOC Incident Response Plan. Every procedure in the IRP was designed with these laws and principles in mind.

Law 1 — Computer Fraud and Abuse Act (CFAA)

The Computer Fraud and Abuse Act (CFAA) is the primary United States federal law that governs computer crime. It makes it illegal to access computer systems without authorization, to exceed authorized access, or to intentionally damage computer systems.

The CFAA is directly relevant to this project because The Sentinel Hybrid-SOC simulates attacks and conducts penetration testing on its own lab environment. The CFAA requires that all attack simulations be confined to systems the operator owns or has explicit written permission to test.

CFAA Requirement	How the Sentinel SOC Complies
No unauthorized access to computer systems	All attack simulations (Atomic Red Team) are run exclusively on Kali Linux — a VM owned and operated by the project. No external systems are targeted.
No intentional damage to systems not owned by the tester	The test-attack directory is isolated on the Kali VM. All file modifications are contained within the lab environment and reversed after testing.
Incident response must be lawful	The IRP authorizes only actions against systems within the lab. Any real-world incident response requires explicit authorization from the system owner before any containment action.

Law 2 — GDPR and Connecticut Data Privacy Act (CTDPA)

The General Data Protection Regulation (GDPR) is a European Union law that governs how personal data must be collected, stored, and protected. The Connecticut Data Privacy Act (CTDPA) is the Connecticut state equivalent, directly applicable to this project given that the DAE Cohort is based in Stafford, CT.

Both laws require organizations to protect personal data using appropriate technical safeguards, to notify affected individuals within 72 hours of a confirmed data breach, and to document their security procedures.

GDPR / CTDPA Requirement	How the Sentinel SOC Complies
Protect personal data with appropriate technical safeguards	AES-256 encryption protects all data at rest and in transit. SHA-256 hashing verifies data integrity. TLS 1.2+ secures all API communications.
Data breach notification within 72 hours	The IRP defines a mandatory Incident Report generation step (Recovery Step 5) that documents the breach scope before the 72-hour notification window closes.
Document security policies and procedures	The Sentinel SOC maintains a formal Security Policy (C2), Incident Response Plan (C1), and Incident Timeline reports that serve as the required documentation.
Minimize data collection to what is necessary	Wazuh agents are configured to collect only security-relevant logs. No personal user data is collected beyond what is required for SOC operations.

C4 CHECK — Laws: 2 relevant laws identified (CFAA and GDPR/CTDPA) with specific compliance requirements and how the Sentinel SOC meets each one.

Ethical Consideration — The Disclosure Dilemma

One of the most challenging ethical questions in cybersecurity is the Disclosure Dilemma: when a security breach occurs, how quickly should the organization inform affected parties, and how much information should be shared?

Disclosing too early — before the scope of the breach is confirmed — can cause unnecessary panic, spread misinformation, and potentially tip off the attacker that they have been detected before containment is complete.

Disclosing too late — or not at all — violates the trust of affected individuals, breaks legal notification requirements (GDPR requires 72 hours), and may allow further harm to occur while victims remain unaware.

How the Sentinel SOC Resolves This Dilemma

The Sentinel IRP balances these competing obligations through a structured notification timeline tied directly to the incident response phases:

IRP Phase	Notification Action	Ethical Justification
Containment (\$3)	Internal alert only — Discord notification to SOC analyst	Premature external disclosure could tip off the attacker before containment is complete.
Eradication (\$4)	Preliminary internal report — scope being confirmed	Facts are being verified. Notifying stakeholders with unconfirmed information violates the duty of accuracy.
Recovery (\$5)	Incident Report generated — confirmed scope documented	Once the full impact is known, transparent and accurate notification fulfills both the legal 72-hour window and the ethical duty to affected parties.
Post-Incident Review	Public-facing disclosure if personal data was affected	GDPR and CTDPA require formal notification to individuals whose data was compromised. This is both a legal obligation and an ethical duty.

C4 CHECK — Ethics: The Disclosure Dilemma identified and explained. The IRP's phased notification approach balances legal compliance with ethical responsibility to affected parties.

How the Plan Upholds Legal and Ethical Principles

Legal Protection — Encryption as Safe Harbor

By implementing AES-256 encryption for all data at rest and in transit, the Sentinel SOC establishes a legal Safe Harbor position. Under GDPR and CTDPA, if encrypted data is stolen during a breach, it may be considered legally unusable — potentially exempting the organization from certain breach notification requirements because the stolen data cannot be read without the decryption key.

Legal Protection — Authorized Testing Only

All attack simulations in this project are conducted exclusively within the Sentinel SOC lab environment on systems owned by the operator. This ensures full compliance with the CFAA's prohibition on unauthorized access. Before any real-world incident response action, explicit written authorization from the system owner is required.

Ethical Protection — Hashing Protects User Credentials

By hashing sensitive information such as passwords using SHA-256, the Sentinel SOC ensures that even if an attacker gains access to the database, actual user credentials remain protected. The attacker obtains only a hash — which cannot be reversed to recover the original password. This fulfills the ethical duty to minimize harm to the users and clients whose data is entrusted to the organization.

Ethical Protection — Transparent and Timely Disclosure

The IRP's structured notification timeline ensures that stakeholders are informed accurately and promptly once the full scope of an incident is confirmed. This balances the ethical obligation of transparency with the practical requirement of accuracy — never disclosing unverified information, but never delaying beyond the legal 72-hour notification window.

Principle	Mechanism	Law / Ethic Upheld
Data confidentiality	AES-256 encryption for all data at rest and in transit	GDPR Art. 32, CTDPA §13, CFAA §1030
Data integrity	SHA-256 hashing of all monitored files via Wazuh FIM	GDPR Art. 5(1)(f) — integrity and confidentiality principle
Authorized access only	All attack simulations confined to owned lab environment	CFAA §1030(a) — no unauthorized computer access
Breach notification	IRP Recovery Step 5 generates Incident Report before 72-hour window	GDPR Art. 33, CTDPA breach notification requirement

Principle	Mechanism	Law / Ethic Upheld
Credential protection	SHA-256 hashing of passwords — irreversible even if stolen	Ethical duty to minimize harm to affected users
Transparent disclosure	Phased notification tied to confirmed incident scope	GDPR Art. 34, ethical duty of transparency to stakeholders

C4 CHECK — Compliance: Plan explains how it upholds both legal requirements (CFAA, GDPR/CTDPA) and ethical principles (disclosure, credential protection) with specific mechanisms for each.